Lecture 3: AES and Mode of Operations

ITDS271: Computer and Communication Security

Dr. Dolvara Gunatilaka

Revision: Crytography

- **Cryptography:** study involving principles and techniques for securing data.
  - **Cipher** is a specific *method* or *algorithm* used to encrypt and decrypt information
  - Technique: **substitution** (monoalphabetic and polyalphabetic) and **transposition**
  - Modern Cipher: **Symmetric** vs **Asymmetric**

- **Cryptanalysis:** Study and practice of analyzing or breaking cryptographic systems
  - **Brute-force attack:** try all possible keys
  - **Cryptanalytic attack**: use mathematical analysis + known weakness

Topics

PART 1: Advance Encryption Standard

- What is AES?
- How does it work?
- Design & Performance

PART 2: Stream Cipher & Mode of Operations

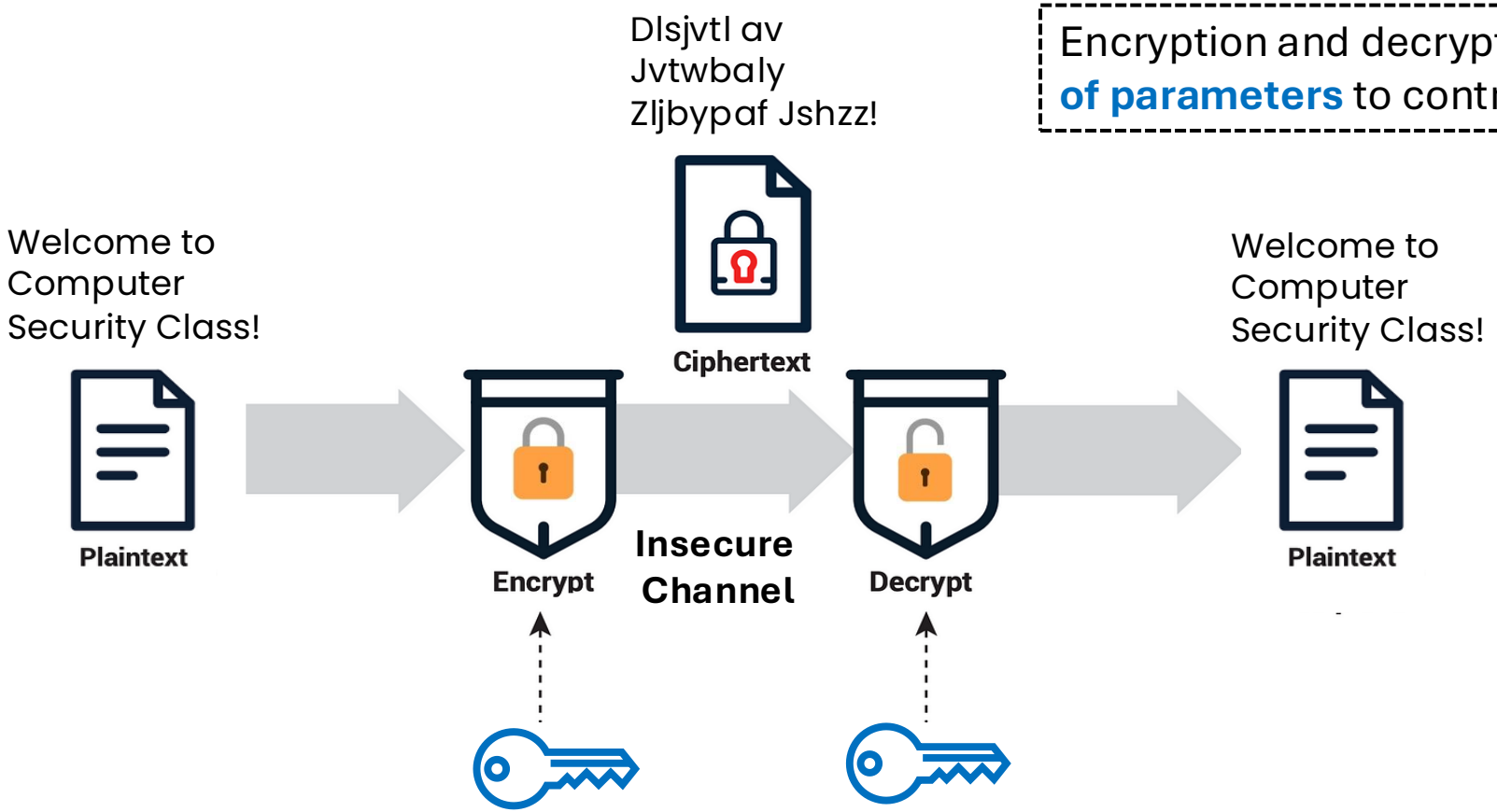
- Stream Cipher → RC4
- Mode of Operations

PART 1

Advanced Encryption Standard (AES)

Symmetric Key Encryption

Encryption and decryption use the **same set of parameters** to control the transformation



Shared secret-key
(distributed to both parties before communication)

Symmetric Key Encryption

There are **two requirements** for secure use of symmetric-key encryption:

1. **Strong encryption algorithm**
   - Assume encryption algorithm is known
2. **Secret key known only to sender /receiver**
   - Imply a secure channel is used to distribute the key

Classical methods

- Substitution: one letter is exchanged for another
- Transposition: the order of letters is rearranged
- Product system: combination of both methods

Modern methods – use complicated combination of classical methods and some mathematical computation

- Data Encryption Standard (DES) – obsoleted
- Advanced Encryption Standard (AES) - currently used

Advanced Encryption Standard (AES)

- DES becomes vulnerable to brute-force attacks and 3-DES provided temporary fix
- In 1997, NIST made a formal call for a new encryption standard
- Published as AES in 2001
- AES Specifications:
  - Unclassified and publicly disclosed
  - Available royalty-free for use worldwide
  - **Symmetric-key** block cipher of **128 bit**
  - Key size: **128, 192 or 256-bit**

In 1998, NIST announced a **group of 15 candidates**

- Out of 15, then narrowed down to 5:

  MARS, RC6, Rijndael, Serpent, and Twofish
- Winner: **Rijndael Cipher**
  - Designed by Rijmen-Daemen in Belgium

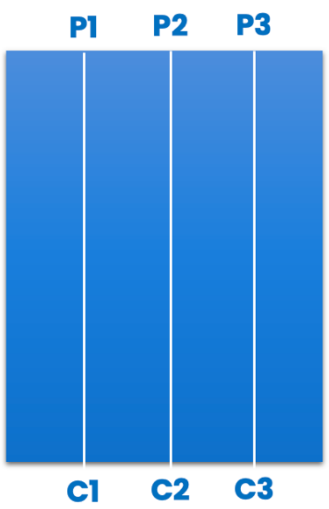
- **Rijndael** is a Dutch language pronounced as "rine-dahl"

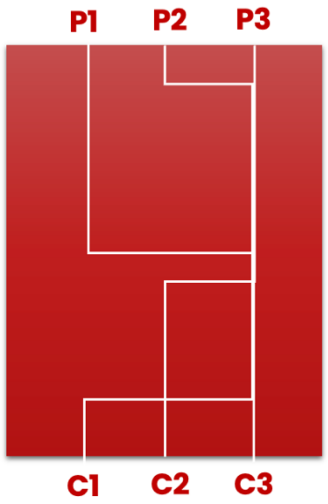
AES Design Principal

- Unlike DES, AES is <u>not</u> a Feistel cipher.
- Instead, it is based on a ***Substitution-Permutation Network (SPN)***
  - Consist of **Substitution (S-Box)** and **Permutation (P-Box)**
  - Introduce by Claude Shannon in 1949
- Provide **confusion** & **diffusion** of message & key
  - **Confusion:** makes relationship between a plaintext and its corresponding ciphertext as complex as possible
  - **Diffusion:** a small change in plaintext should cause many changes (possibly more than half) in ciphertext and vice versa

Substitution-Permutation Network (SPN)

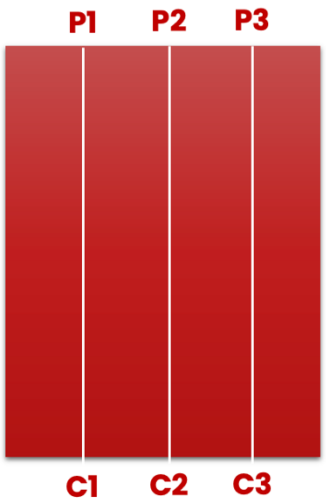
Confusion

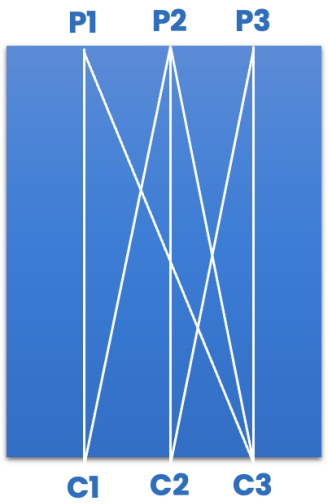




Which one make it harder for you <u>to find the relationship</u> between the input and output?

Diffusion





Which one make it so that **changing 1 input cause multiple output to change?**

AES (Rijndael)

- Block cipher (**128-bit block**)
- Key size: **128/192/256 bits**
- **Contains iterative process (has rounds)**
  - Operates on an entire data block (128 bit) in every rounds
  - AES processes data as a block of 4 columns of 4 bytes
- Strong mathematical foundation: **GF(2^8)**
- **Designed to be/considering:**
  - Resistant against known attacks
  - Speed and code compactness for many CPUs
  - Simplicity

A block of data (128 bits) represented as a State Array, a 4x4 matrix

B0	B4	B8	B12
B1	B5	B9	B13
B2	B6	B10	B14
B3	B7	B11	B15

AES Structure (1)

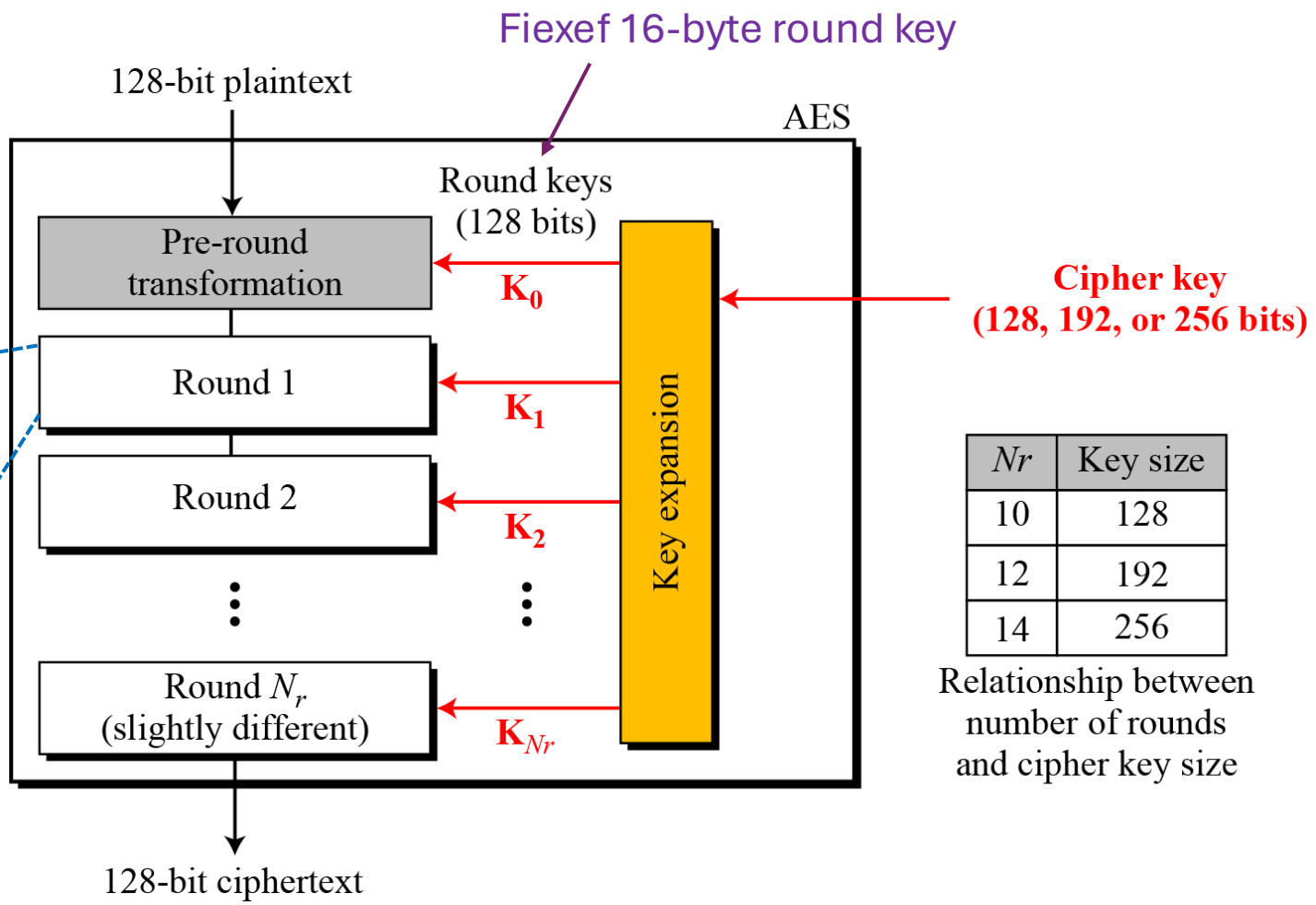
- **Number of rounds** depend on the key size
- Each round contains **four** operations

Substitue Bytes

ShiftRows

MixedColumns

AddRoundKey

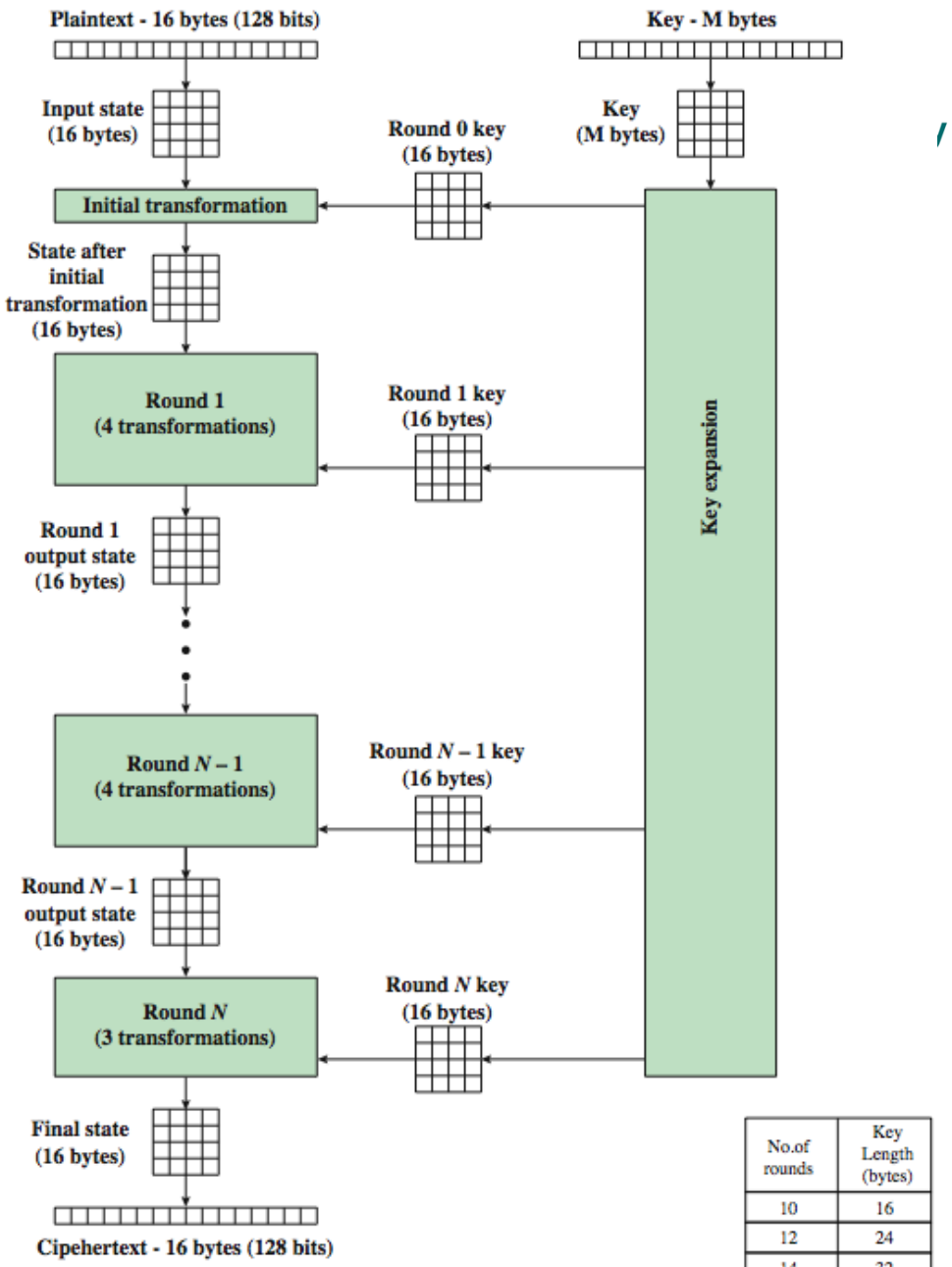


Nr	Key size
10	128
12	192
14	256

Relationship between number of rounds and cipher key size

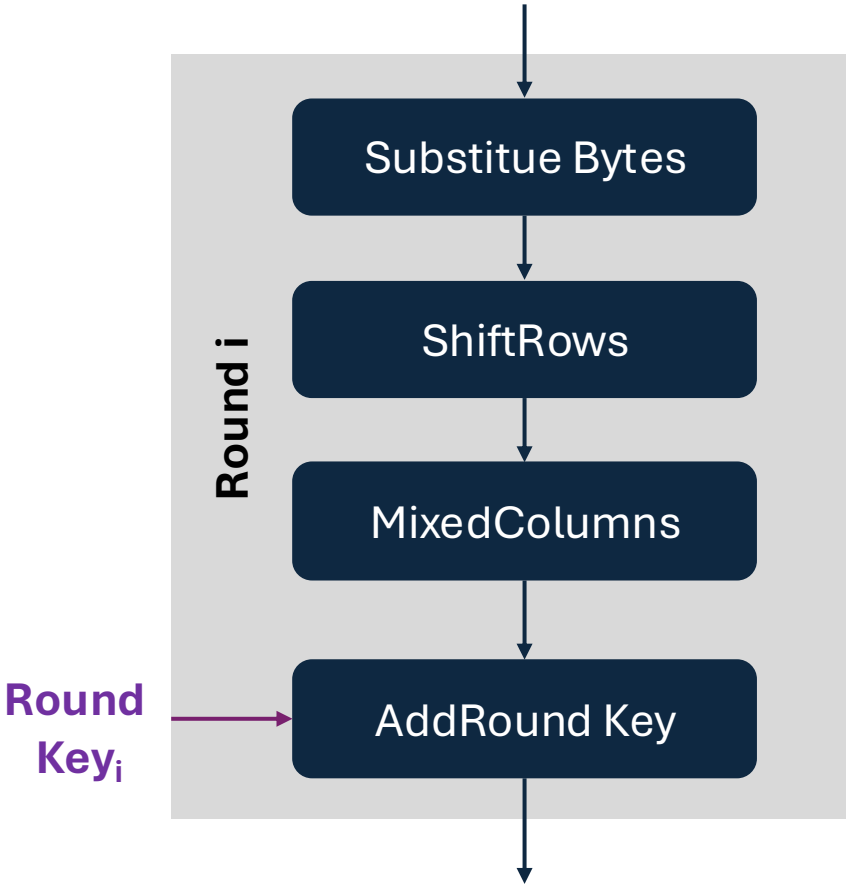
AES Structure (2)

- **Initial transformation:**
  - The plaintext is XORed with the initial round key (derived from the secret key) → **AddRoundKey**
- **Round 1 to (N-1)**
  - Consists of four **SubBytes, ShiftRows, MixColumns, AddRoundKey**
- **Final Round (N):**
  - Consist of **SubBytes, ShiftRows, AddRoundKey**
  - Omit the **MixColumns**
- **Output:** The final state array is the 128-bit ciphertext



No.of rounds	Key Length (bytes)
10	16
12	24
14	32

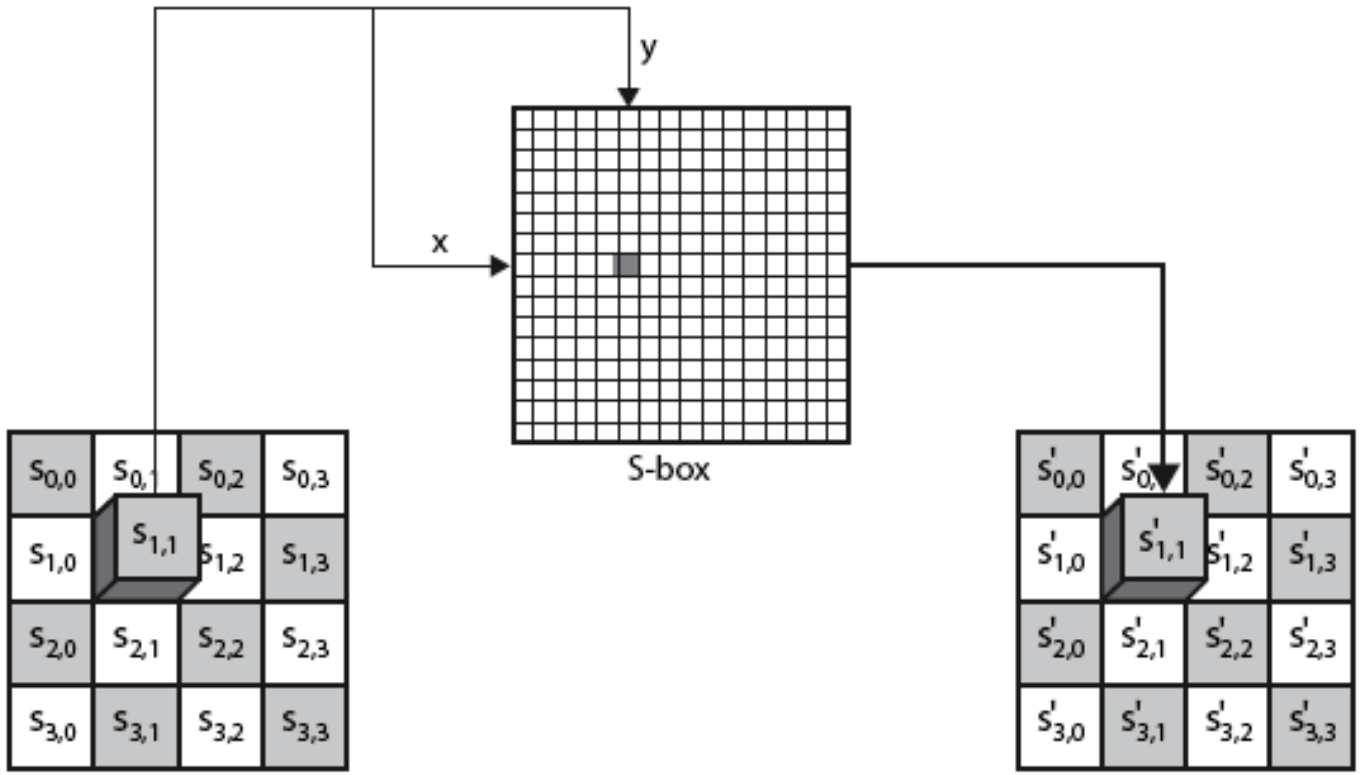
Each AES Round



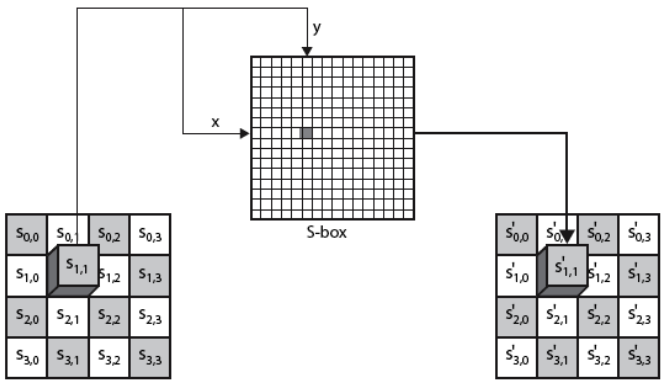
- **Substitute Bytes (SubBytes):**
  - S-box is used to perform byte-by-byte substitution
- **ShiftRows:**
  - Simple permutation
  - Cyclically shift to the left
- **MixColumns:**
  - Substitution making use of arithmetic over GF(2^8)
- **AddRoundKey:**
  - Bitwise XOR operation of the current block with a round key

AES Round: SubBytes

- Each individual byte **($S_{i,j}$)** of the **state** is mapped into a new byte **($S'_{i,j}$)**
  - Row (x) = leftmost 4 bits
  - Column (y) = rightmost 4 bits
- Use a simple look up table called **S-Box** represented as 16x16 matrix



AES Round: SubBytes



(a) S-box

x \ y	0	1	2	3	4	5	6	7	8	9	A	B	C	D	E	F
0	63	7C	77	7B	F2	6B	6F	C5	30	01	67	2B	FE	D7	AB	76
1	CA	82	C9	7D	FA	59	47	F0	AD	D4	A2	AF	9C	A4	72	C0
2	B7	FD	93	26	36	3F	F7	CC	34	A5	E5	F1	71	D8	31	15
3	04	C7	23	C3	18	96	05	9A	07	12	80	E2	EB	27	B2	75
4	09	83	2C	1A	1B	6E	5A	A0	52	3B	D6	B3	29	E3	2F	84
5	53	D1	00	ED	20	FC	B1	5B	6A	CB	BE	39	4A	4C	58	CF
6	D0	EF	AA	FB	43	4D	33	85	45	F9	02	7F	50	3C	9F	A8
7	51	A3	40	8F	92	9D	38	F5	BC	B6	DA	21	10	FF	F3	D2
8	CD	0C	13	EC	5F	97	44	17	C4	A7	7E	3D	64	5D	19	73
9	60	81	4F	DC	22	2A	90	88	46	EE	B8	14	DE	5E	0B	DB
A	E0	32	3A	0A	49	06	24	5C	C2	D3	AC	62	91	95	E4	79
B	E7	C8	37	6D	8D	D5	4E	A9	6C	56	F4	EA	65	7A	AE	08
C	BA	78	25	2E	1C	A6	B4	C6	E8	DD	74	1F	4B	BD	8B	8A
D	70	3E	B5	66	48	03	F6	0E	61	35	57	B9	86	C1	1D	9E
E	E1	F8	98	11	69	D9	8E	94	9B	1E	87	E9	CE	55	28	DF
F	8C	A1	89	0D	BF	E6	42	68	41	99	2D	0F	B0	54	BB	16

$(S_{i,j})$ = 50 (HEX)

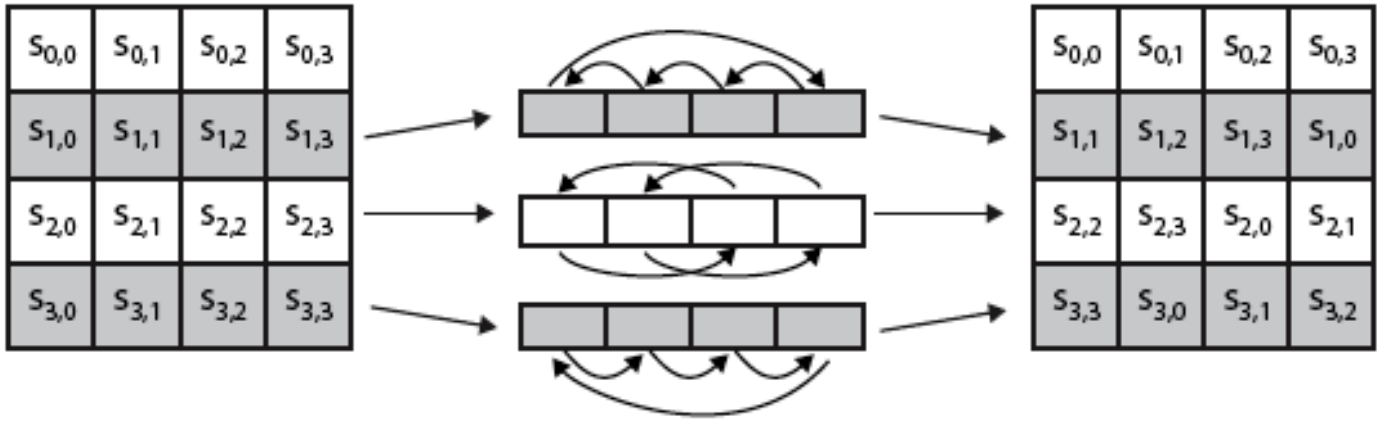
What is $(S'_{i,j})$?

- Row (x) = _____ (HEX)
- Column (y) = _____(HEX)
- **$(S'_{i,j})$ =** _____(HEX)

AES Round: ShiftRows

- Shift to the **left** by certain number of positions
  - Row 0: No shift
  - Row 1: Shift left by one byte
  - Row 2: Shift left by two bytes
  - Row 3: Shift left by three bytes

Ensure that the **4 bytes of the same column** are spread out to all four different columns

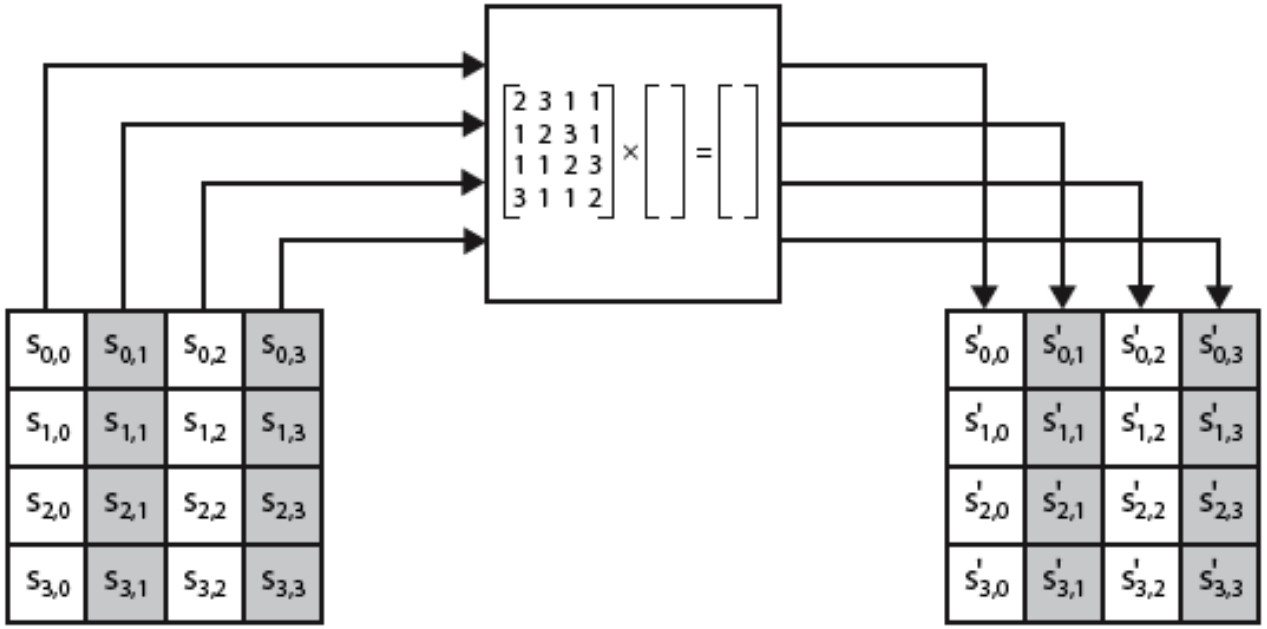


Examples

[a0 a1 a2 a3]
[b0 b1 b2 b3]
[c0 c1 c2 c3]
[d0 d1 d2 d3]

AES Round: MixColumns

- Operate on each column individually
- Multiplying a 4x4 constant matrix with each column
- <u>Omit</u> in the final round (N)



Polynomia Multiplication/Addition

- Polynomial multiplication
  - Multiply by 01 → no chanage
  - Multiply by 02 → Left shift by one bit, then reduce (XOR) with 0x11B if overflow occurs.
  - Multiply by 03 → 02·a ⊕ a.
- Addition = XOR

Decimal	Binary	Hexadecimal
1	0001	1
2	0010	2
3	0011	3
4	0100	4
5	0101	5
6	0110	6
7	0111	7
8	1000	8
9	1001	9
10	1010	A
11	1011	B
12	1100	C
13	1101	D
14	1110	E
15	1111	F

AES Round: MixColumns

Repeat multiplication for all rows and all columns

Constant Matrix

2	3	1	1
1	2	3	1
1	1	2	3
3	1	1	2

×

State Matrix

87	F2	4D	97
6E	4C	90	EC
46	E7	4A	C3
A6	8C	D8	95

→

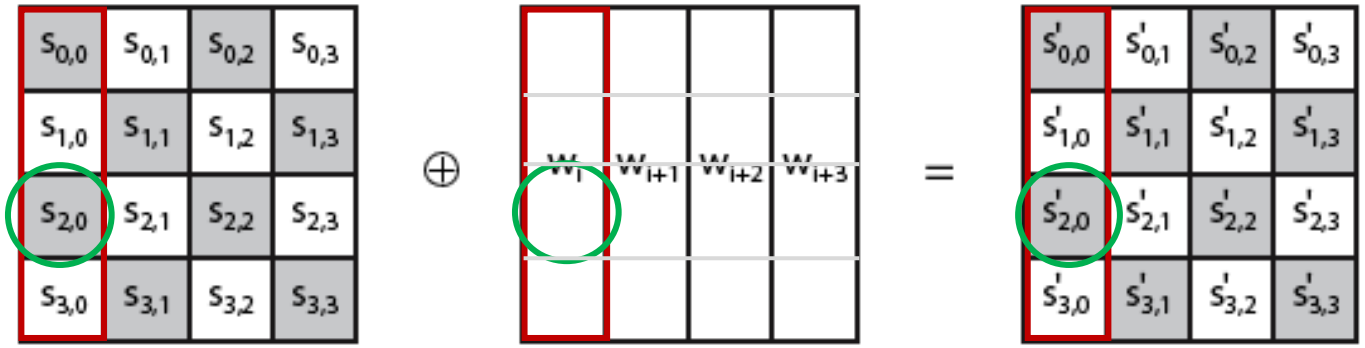
47	40	A3	4C
37	D4	70	9F
94	E4	3A	42
ED	A5	A6	BC

- 87 Multiply by 02
  - 87 = 1000 0111
  - 2 x 1000 0111: 1 0000 1110 (0E) XOR 0001 1011 (1B) -> 0001 0101 (15)
- 6E Multiply by 03
  - 6E = 0110 1110
  - 2 x 0110 1110 : 1101 1100 (DC) XOR 0110 1110 (6E) -> 1011 0010 (B2)
- 46 Multiply by 01 (no change)
  - 46 = 0100 0110
- A6 Multiply by 01 (no change)
  - A6 = 1010 0110

Add: 15 XOR B2 XOR 46 XOR A6 = 47

AES Round: AddRoundKey

- **XOR** state information with 128-bits of the round key
- A Round key consists of four distinc words
- Process data by-column basis



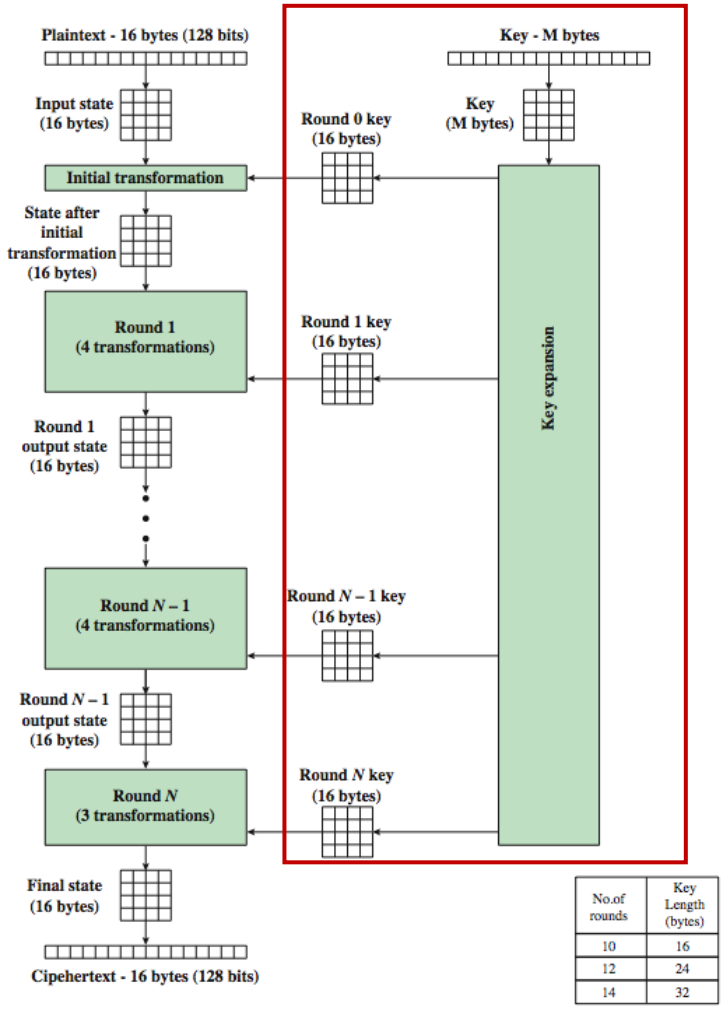
A	B	Q
0	0	0
0	1	1
1	0	1
1	1	0

S(2,0) = 3A → 0011 1010
W(3,i) = 25 → 0010 0101

S'(2,0) = _____

AES Key Expansion

- The single secret key (**128, 192, or 256** bits) is expanded into a **key schedule**, which is a sequence of separate **round keys**
- Key schedule is an array of **44/52/60 32-bit words**
- If there are **N rounds** of encryptions, then we need **N+1 round keys** (128 bits)



No.of rounds	Key Length (bytes)
10	16
12	24
14	32

Strengths of AES

Strength of AES Key Expansion

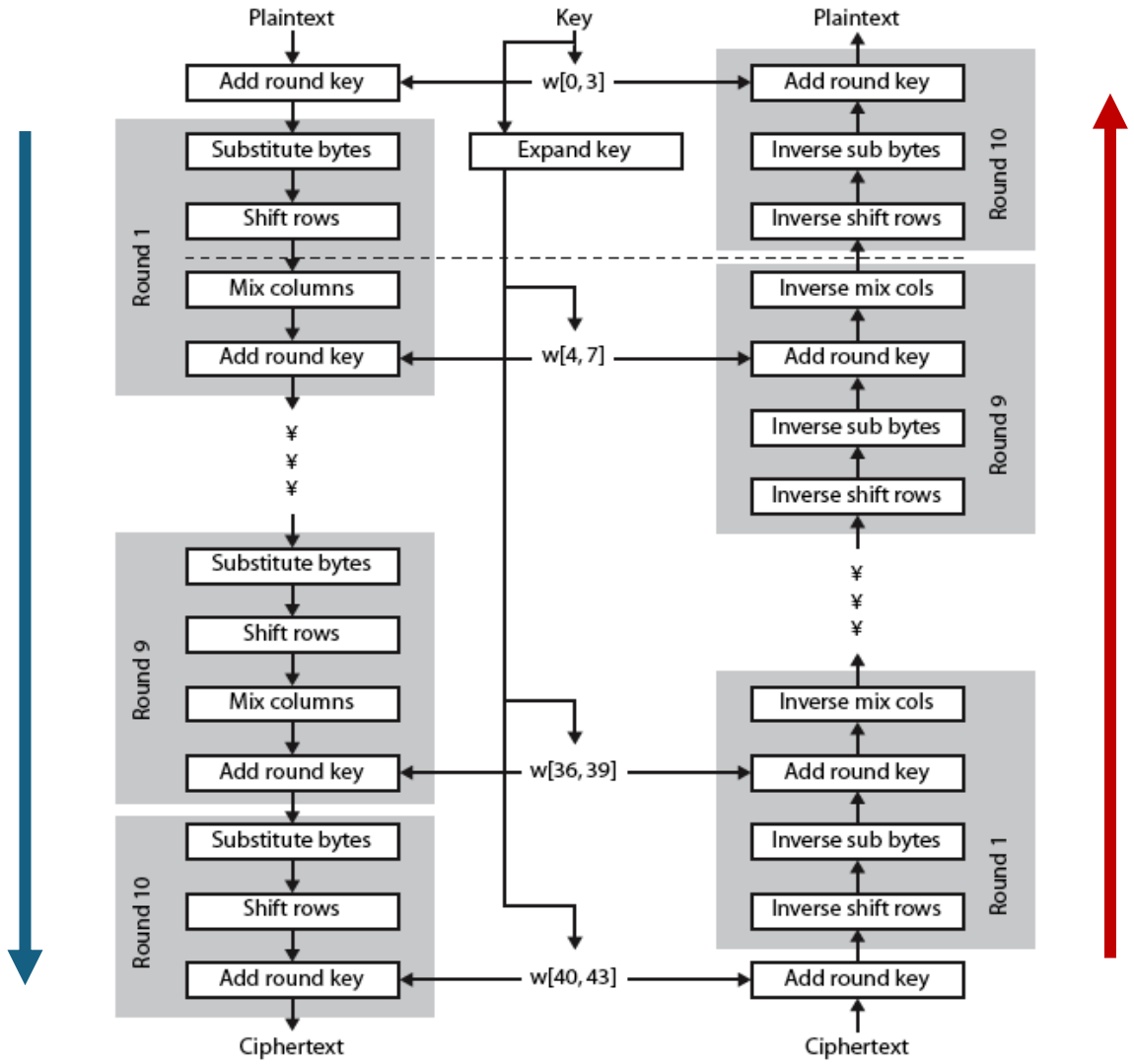
- Prevent pattern repetition: each round uses a unqiue key
- Enhance confusion and diffusion
- Nonlinearlity and uniqueness
- Fast operation: round keys are precomputed, allowing AES to run efficienly

Strength of AES

- Strong security: provides excellent resistance to known cryptanalytic attacks
- **Efficiency:** highly efficient in both hardware and software implementations
- **Flexible Key Lengths:** allows users to select a security level appropriate for their needs.
- **Global Adoption:** provides confidence in its security and interoperability.

AES Encryption and Decryption

- Round structure of AES
- For **128-bit key:**
  - **10 rounds**
  - Expanded key = **44 words** [W0–W43]
  - **11 round keys**



PART 2

Stream Cipher and Mode of Operations

Two Flavors of Encryption

Block Cipher

- Encrypt data in fixed-size ***blocks*** (e.g., 64 bits, 128 bits).
- The same key is used for each block, but the encryption process is often made dependent on previous blocks
- **Analogy:** Encrypting a document page by page

DES | 3-DES | AES

Stream Cipher

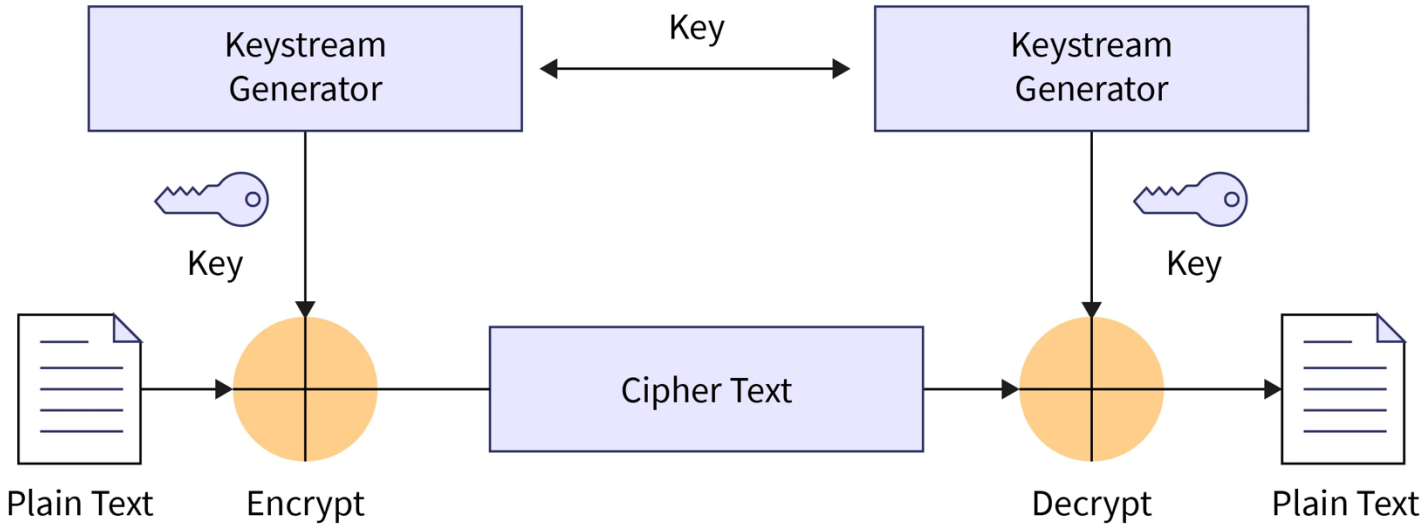
- Encrypt data ***bit by bit*** or byte by byte.
- Generate a pseudorandom keystream, which is then combined (typically XORed) with the plaintext
- **Analogy:** Encrypting a document letter by letter as it's being written.

RC4 | Salsa20 | ChaCha20

Stream Cipher

- A stream cipher is a **symmetric-key cipher** where plaintext digits, data stream, are combined with a pseudorandom cipher digit stream (a key stream)
- Each plaintext digit is encrypted one at a time with the corresponding digit of the key stream, to give a digit of the ciphertext stream
- The input plaintext is processed continuously
- Each key is generated via **pseudorandom number generator (PRNG)**
- The output ciphertext is produced as a stream of random-like numbers (unpredictable)
- **Advantages:** fast, simple coding, low error propagation

Encryption = XOR



Encryption

1100 1100	input plaintext
⊕ 0110 1100	key stream
1010 0000	output ciphertext

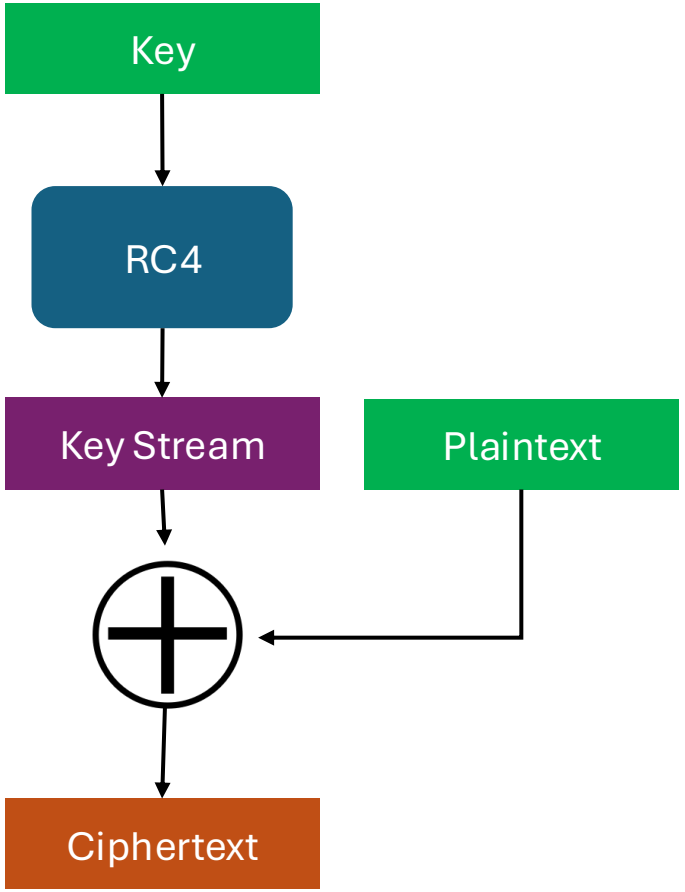
Decryption

1010 0000	input ciphertext
⊕ 0110 1100	key stream
1100 1100	output plaintext

Image: https://www.scaler.com/topics/block-cipher-vs-stream-cipher/

Stream Cipher: RC4

- A proprietary cipher **owned by RSA Security**
- Another design from **Ron Rivest** in 1987, simple but effective
- Variable key size (40-2,048) bits, **byte-oriented** stream cipher
- 8-16 machine operations are required per output byte (very fast!)
- Widely used in web SSL/TLS standards and wireless WEP and WPA (part of IEEE 802.11)
- Has two main algorithms:
  - Key Scheduling Algorithm (KSA)
  - Pseudo-Random Generatign Algorithm (PRGA)



RC4: Key Scheduling Algorithm (KSA)

Initializes a 256-byte state array S based on the secret key

1. Initialization: The S-array is initialized

```
for i = 0 to 255:
    S[i] = i
```

2. Permutation: The S-array is then permuted using the secret key.

```
j = 0
for i = 0 to 255:
    j = (j + S[i] + key[i mod keylen]) mod 256
    swap S[i], S[j]
```

Output: A **permuted S-array** that depends on the secret key

RC4: Pseudo-Random Generation Algorithm (PRGA)

```
i = 0, j = 0

For each byte Pi in plaintext P
  i = (i + 1) mod 256
  j = (j + S[i]) mod 256
  swap S[i], S[j]
  t = (S[i] + S[j]) mod 256
  keystream_byte = S[t]

  Ci = Pi XOR keystream_byte
```

Generates the keystream byte by byte

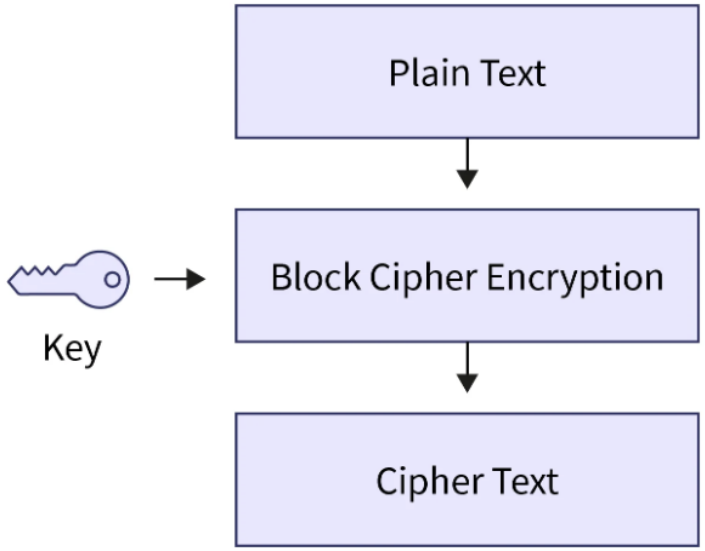
XOR keystream with a byte of plaintext to produce a byte of ciphertext

Stream Cipher: RC4 Strengths and Weakness

- Once a popular stream cipher due to its <u>simplicity, speed, and variable key length</u>
- But, RC4 is ***no longer considered secure***
  - **Officially deprecated** in most standards: prohibited in TLS, WEP/WPA that uses RC4 is replaced by WPA2/AES, etc.
- **Key Stream Reuse**: allow attackers to derive XOR of two plaintexts (most critical weakness)
- **Biased Output:** the initial output bytes of RC4 are not truly random and exhibit statistical biases
- **Related-Key Attacks:** vulnerabilities have been found where knowledge of one key can reveal information about others.

Block Cipher

- Plaintext is being processed **1 block at a time**
- Block size is **big enough** to avoid known-plaintext attack
  - **64 or 128-bit** blocks are typical
- The **output should look random**
  - No correlation between plaintext and ciphertext (i.e., confusion)
  - Information (bits) in each block is spread through out a single block or across all blocks (i.e., diffusion)



Block Cipher: Mode of Operations

Features

- Block size
  - Larger block sizes mean greater security
- Key size
  - Larger key size means greater security
- Number of rounds
  - Multiple rounds offer increasing security
- **Encryption modes (mode of operations)**
  - **Define how a message larger than the block size is encrypted**

Six modes of operations are defined in NIST FIPS SP 800-38A

1) **ECB:** Electronic Codebook
2) **CBC:** Cipher Block Chaining
3) **CFB:** Cipher Feedback
4) **OFB:** Output Feedback
5) **CTR:** Counter
6) **GCM:** Galois Counter Mode

"Can be used with any block cipher"

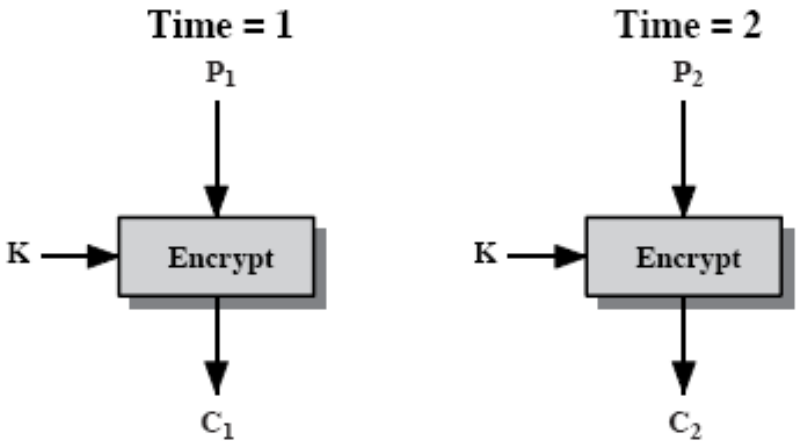
Mode of Operations: ECB

Electronic Code Book (ECB)

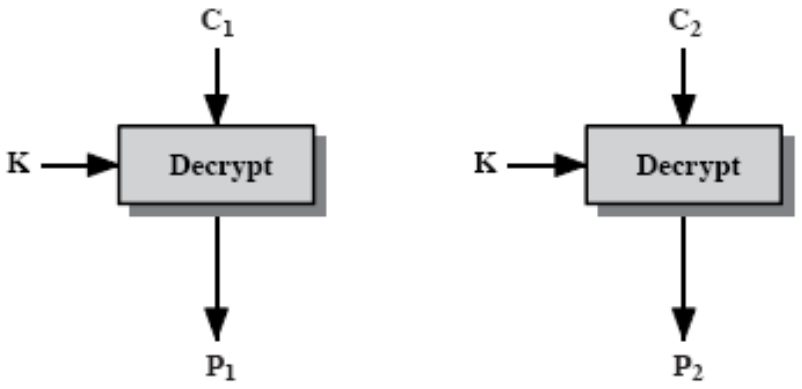
- Simplest of all
- Message is broken into <u>independent blocks</u> and <u>encrypted separately with the same key</u>

$$C_i = E_K(P_i)$$

- **Use cases** is very limited:
  - E.g., secure transmission of a single value



Encryption



Decryption

Mode of Operations: ECB

Advantages:

- Simple
- Can be processed in parallel
- No **chaining dependency** (missing or fail to decrypt one block will not effect the rest)

Limitations:

- Message repetitions may show in the ciphertext, particularly with graphical data
- Identical plaintext blocks results in identical ciphertext blocks (pattern leaks)
- blocks being independent is <u>also considered a weakness</u>
  - Modify (e.g., substitue a block with another)
  - Replay attack

Original image

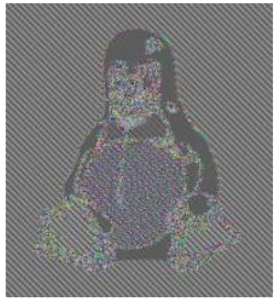


Image encrypted using ECB

There are **patterns** left
(a lot of them actually!)

Mode of Operations: CBC

Mahidol University

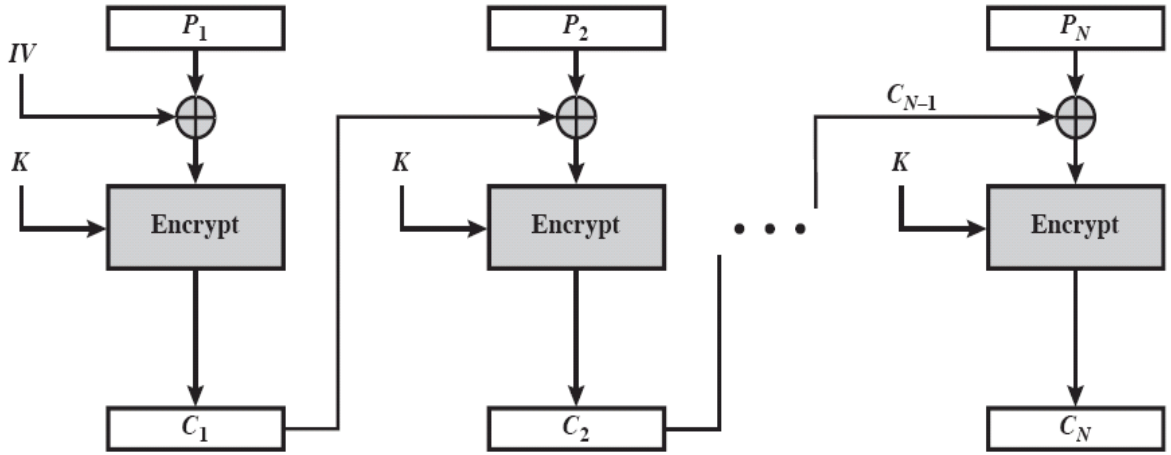
Cipher Block Chaining (CBC)

- Message is broken into blocks and then linked together in encryption operation
- Each previous cipher blocks is chained with current plaintext block
- Use **Initialization Vector (IV)** to start process
  - IV needs to be *random (unpredictable)*, but it does not have to be a secret
  - Never reuse IV
- **Use cases:**
  - Bulk data encryption,
  - Authentication (e.g., CBC-MAC)

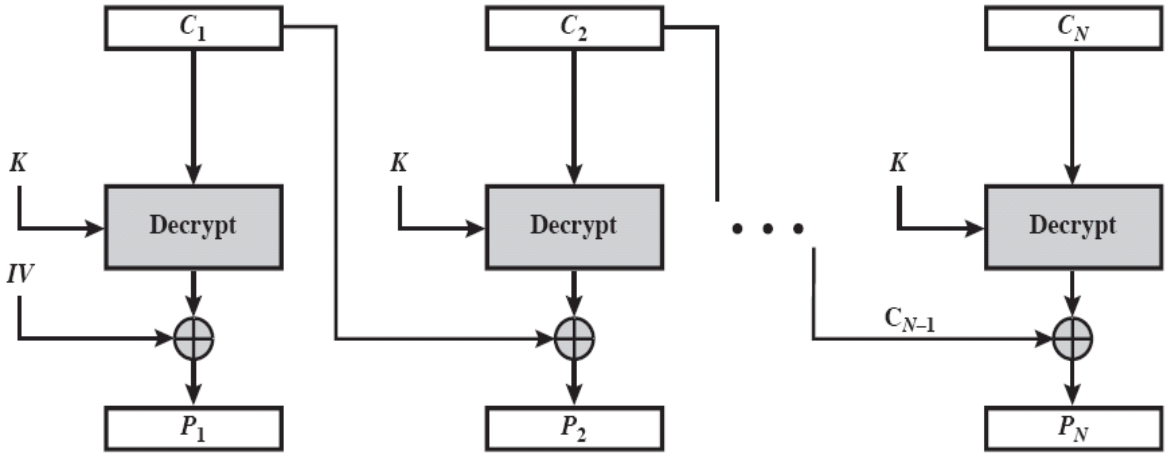
$$C_i = E_K(P_i \oplus C_{i-1})$$
$$C_0 = IV$$

Mode of Operations: CBC

Cipher Block Chaining (CBC)



Encryption



Decryption

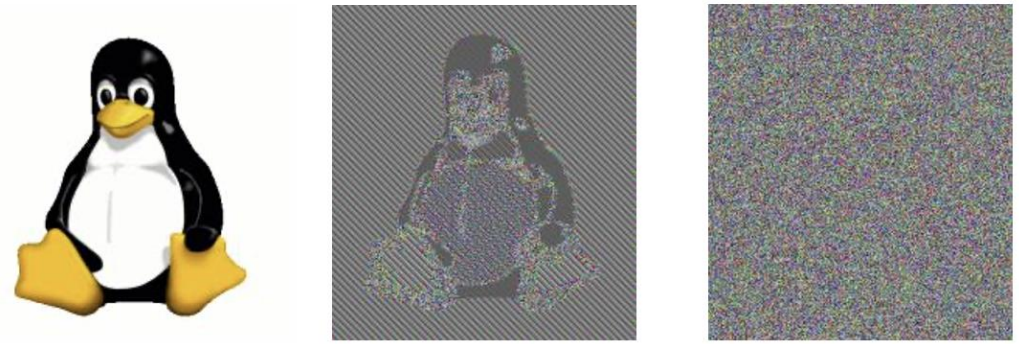
Mode of Operations: CBC

Advantages:

- Ciphertext block depends on all blocks before it
- Any change to a block affects all following ciphertext blocks
- Prevent replay attack and modification

Limitations:

- Still need IV: IV must be known to both sender and receiver
- If IV is sent in clear, the <u>attacker can change some bits of the first block and then change IV</u> value to compensate it
- Encryption is sequential, cannot be parallelized



Original image | Image encrypted **using ECB** | Image encrypted **using other modes**

Message Padding

- How to deal with a possible last short block
  - The last block which its size is smaller than the predetermined fixed block size
- Essential for block ciphers in modes like **ECB**, **CBC**.
- We use **padding** using either
  - Add **N bytes**, each with the value N (in hexadecimal) [**PKCS#7**]
  - Pad the last block along with the count of pad size [**ANSI X.923**]
    - E.g., given an example of 8-byte block of data **[a1 b2 c3 00 00 00 00 05]**
- There are also other modes requiring <u>no padding</u> as well.
  - "Cipher Stealing" mode

Stream Mode of Operations

- Operates on small units (bit, or bytes)
  - Suitable for real-time data
- Convert block cipher into stream cipher
- **Examples:**
  - Cipher Feedback (CFB)
  - Output Feedback (OFB)
  - Counter (CTR)
  - Galpis Couter Mode (GCM)
- Use block ciphers as forms of pseudorandom number generators (PRNGs)

Mode of Operations: CFB

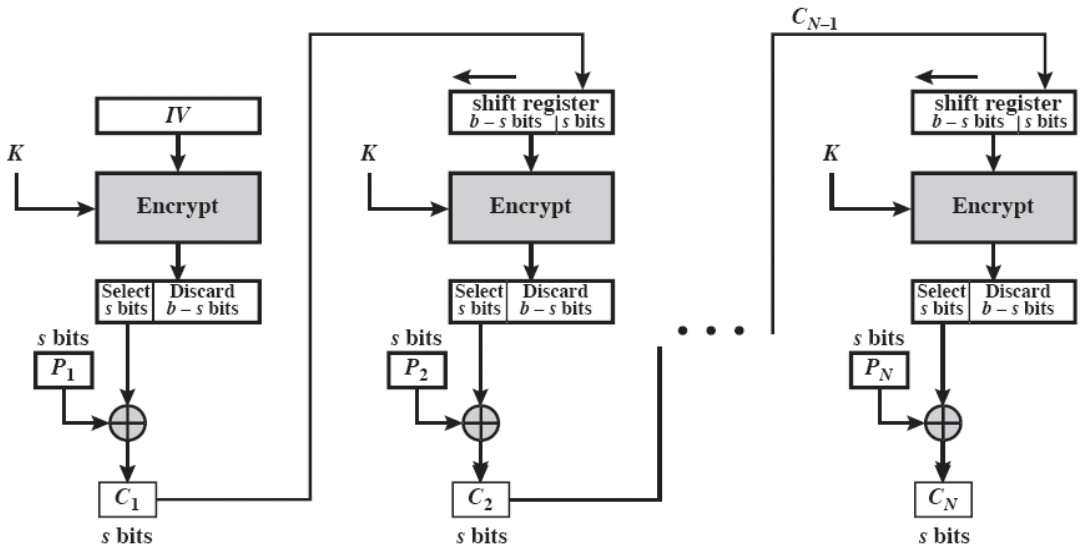
Cipher Feedback

- Message is treated as a stream of bits
- Added to the output of the block cipher
- **Result is fed back** for the next stage
- Standard allows any number of bits (1, 8, 64, 128, etc.) to be fed back
  - *Denoted as* CFB-1, CFB-8. CFB-64, ...
- **Most efficient method** is to **use all bits** in block (64 or 128)

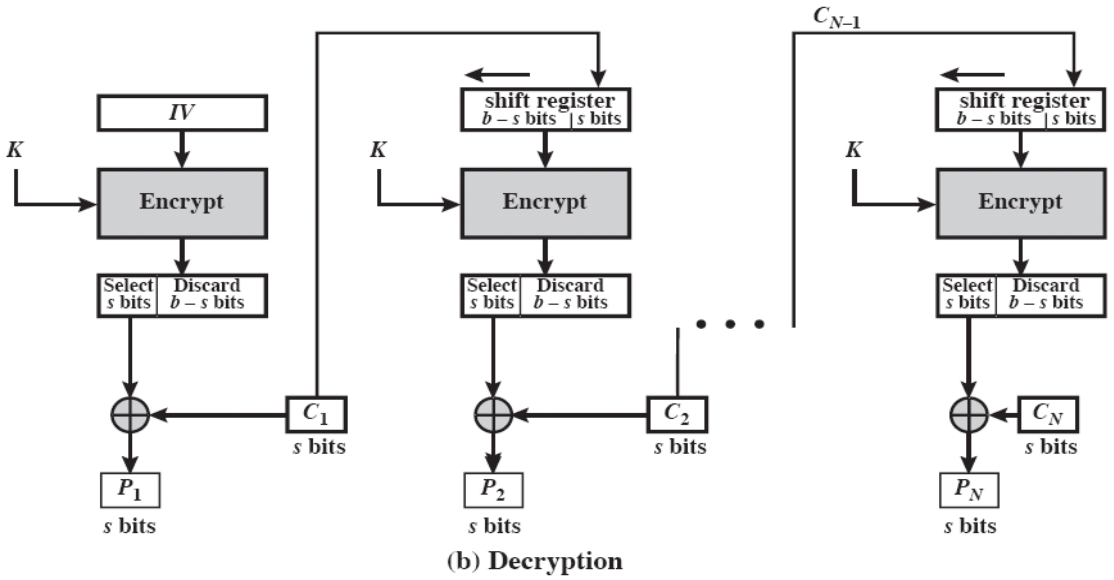
- **Use cases:**
  - Stream data encryption,
  - Authentication (CFB-MAC)

$$C_i = P_i \oplus E_K(C_i\text{-}1)$$
$$C_0 = IV$$

Mode of Operations: CFB



Encryption



Decryption

Mode of Operations: CFB

Advantages:

- Most common stream mode
- Convert block cipher into stream cipher

Limitations:

- Use block cipher for encryption at both ends
- Errors propagate for several blocks after the error
- Not appropriate for using over a “noisy” link due to error propagation
- Cannot be computed in parallel or in advance

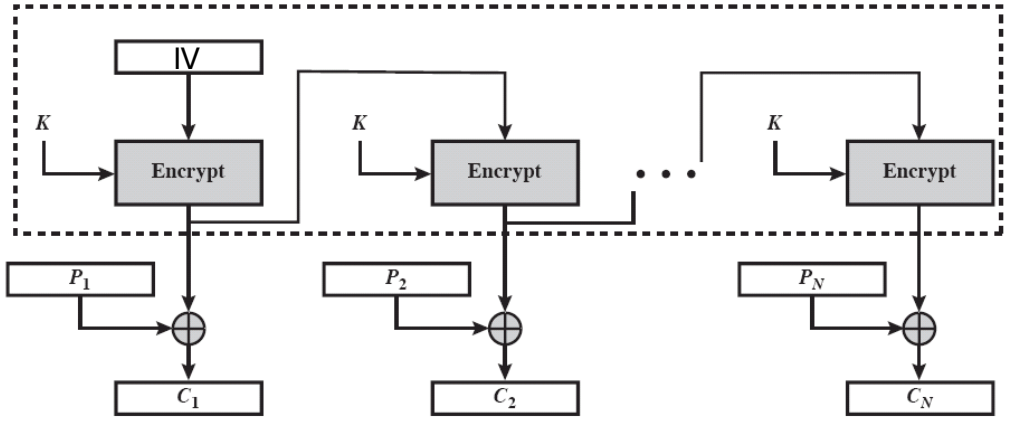
Mode of Operations: OFB

Output Feedback

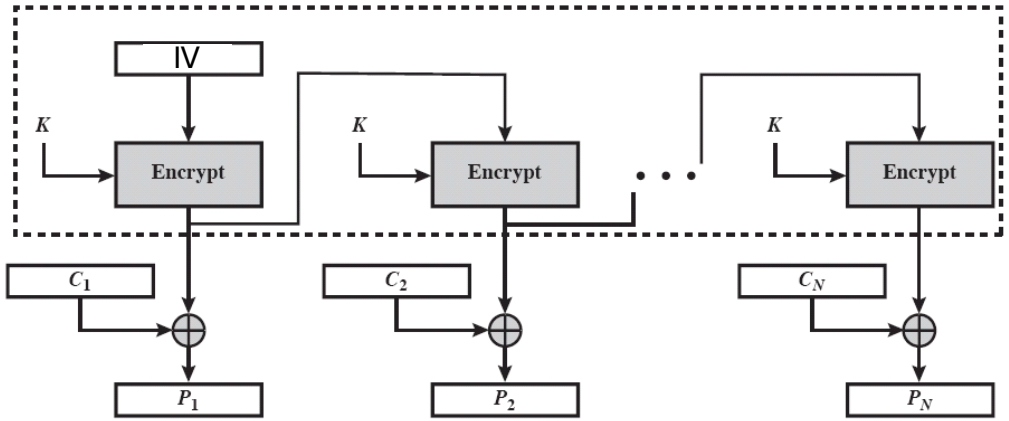
- Messages is treated as a stream of bits
- Output of cipher is then added to the message
- Output is then fed back as an input of the cipher in the next round
- Can be <u>computed in advance</u>
- **Use casse:**
  - Stream encryption on noisy channels
  - Applications where pre-computation of the keystream is beneficial.

$$
\begin{aligned}
C_i &= P_i \oplus O_i \\
O_i &= E_K(O_{i-1}) \\
O_0 &= IV
\end{aligned}
$$

Mode of Operations: OFB



(a) Encryption



(b) Decryption

Advantages

- Bit errors do not propagate
- Can be used with noisy channel
- Keystram can be pre-computed

Limitations:

- Never reuse the same sequence (i.e., key and IV)
- Sender and receiver must remain in sync
- Research showed that only <u>full block feedback</u> (i.e., CFB-64 or CFB-128) should ever be used!

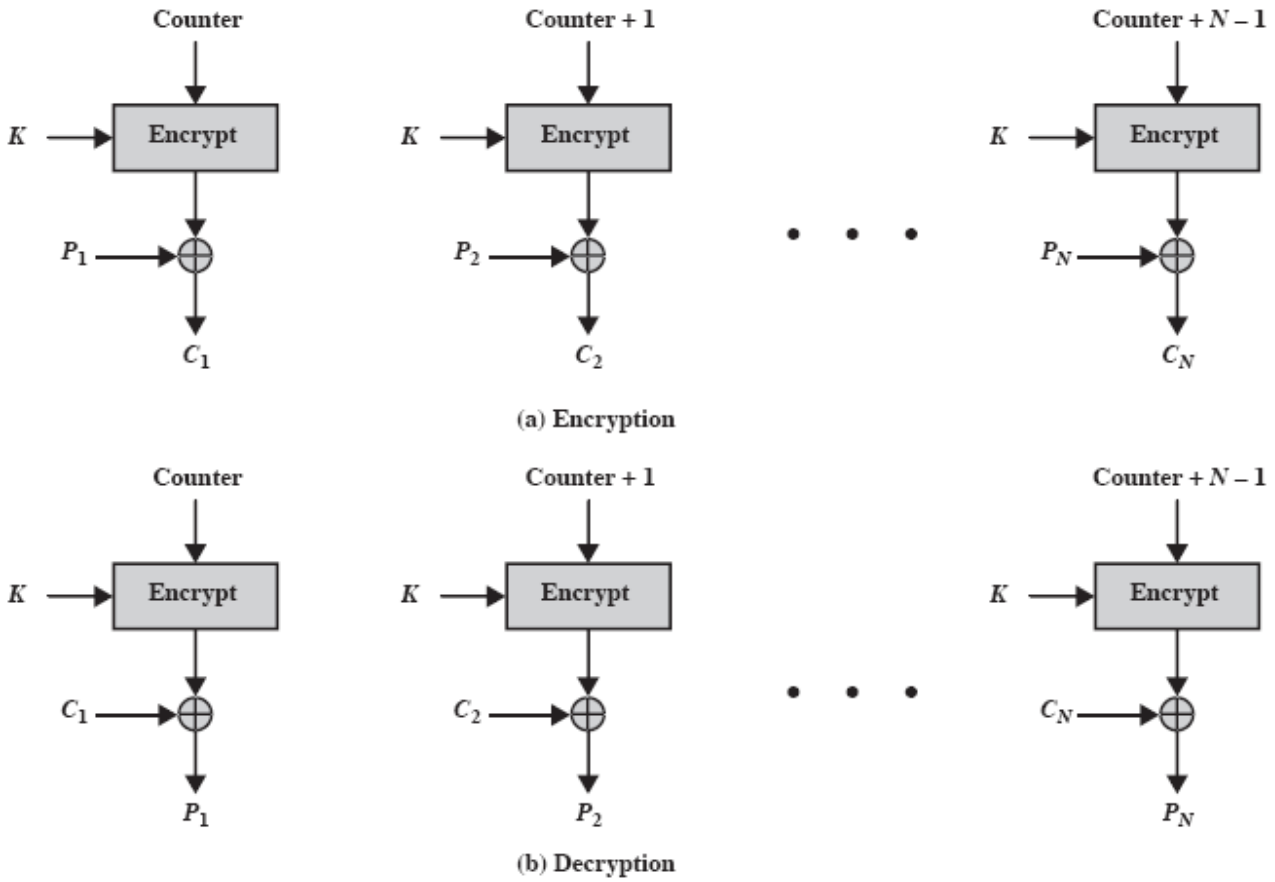
Mode of Operations: CTR

Counter

- Similar to OFB but encrypts counter value rather than any feedback value
- Must have a different key and counter value for every plaintext block (never reused)
- **Use case**: high-speed network encryption

$$C_i = P_i \oplus O_i$$
$$O_i = E_K(i)$$

Mode of Operations: CTR



Advantages

- Provable security (good as other modes)
- **Efficiency**
  - Parallel encryption in both software and hardware
  - Can be preprocessed in advances
  - Good for bursty high speed links

Limitations:

- Never reuse key and counter values

Mode of Operations: GCM

Galois Counter Mode used a block cipher that combines:

- **CTR mode** for encryption, ensuring fast, parallelizable encryption
- **Galois field multiplication** for authentication, verifying that data has not been tampered with.

- **Use Cases:** widely adopted in modern protocols → ***AES/GCM***
  - E.g., TLS 1.2/1.3, IPsec, SSH, secure storage systems
- Advantages: provide confidentiality + integrity + authenticity and highly efficient
- Limitations: *nonce r*euse is catastrophic (just like CTR), and more complex

Source: https://csrc.nist.rip/groups/ST/toolkit/BCM/documents/proposedmodes/gcm/gcm-spec.pdf

Summary

- **AES (Rijndael) Algorithm:** symmetric block cipher (128 bits)
  - Based on substitution-permutation network (SPN)
  - Iterative process (round): SubBytes, ShiftRows, MixColumns, AddRoundKey
- **Stream cipher:** encrypt data bit by bit or byte by byte
  - RC4
- **Block cipher**: encrypt data in fixed size blocks
  - Mode of operations: handle data that is larger than the block size
  - ECB, CBC
  - CFB, OFB, CTR, GCM → use block cipher to generate keystream

มหาวิทยาลัยมหิดล
Mahidol University

ห้ามมิให้นักศึกษาทำซ้ำ ดัดแปลง หรือใช้ประโยชน์จากงานอันมีลิขสิทธิ์ปรากฏอยู่ในระบบการศึกษาอิเล็กทรอนิกส์ (E-Learning) ของมหาวิทยาลัย ไม่ว่าจะทั้งหมดหรือบางส่วนโดยไม่ได้รับอนุญาตจากมหาวิทยาลัย นอกเหนือจากการศึกษาส่วนบุคคล ทั้งนี้ การทำซ้ำ ดัดแปลง หรือเผยแพร่ต่อสาธารณชนซึ่งงานอันมีลิขสิทธิ์ **จะมีโทษปรับตั้งแต่ 20,000 บาท ถึง 200,000 บาท และหากเป็นการกระทำเพื่อการค้า จะมีโทษจำคุกตั้งแต่ 6 เดือน ถึง 10 ปี หรือปรับตั้งแต่ 100,000 บาท ถึง 800,000 บาท หรือทั้งจำทั้งปรับ**

Unless allowed by Mahidol University, the User shall not copy, modify, or exploit in part or in whole of the copyrighted materials on the Platform, other than for your own individual study. The copy, modify or communication to public of the copyrighted materials shall be inflicted with a fine from 20,000 Baht up to 200,000 Baht. If the offence is committed with the commercial purpose, the offender shall be inflicted with imprisonment for a term from 6 months up to 10 years or a fine from 100,000 Baht up to 800,000 Baht or both imprisonment and fine.